STUDY UNIT 2

Database & Big Data Security

From locked filing cabinets to billion-record breaches - how we protect the data behind every system

35-minute session | ITRI625 | Based on Pfleeger, Security in Computing (5th Ed.), Ch. 7 + current threat intelligence

Study Unit 2 Outcomes

By the end of this session you will be able to:



Explain database components and why databases need dedicated security controls



Describe the CIA triad and the reliability/integrity requirements of a database



Compare access control models (DAC, MAC, RBAC) and authentication techniques



Identify and counter the inference problem in sensitive data disclosure



Evaluate the security and privacy implications of data mining and Big Data (the 5 V's)



Relate these concepts to real, recent breaches in South Africa and globally

Quick Recap: What Is a Database?

An organised collection of data, stored electronically, built for easy access, management and updating.

1

Cabinet = Database

The entire secured structure holding everything

2

Folders = Tables

Group related information (e.g. Students, Orders)

3

Files = Records

Individual rows with the actual data values

Why it matters for security:

DBMS, schema, queries, indexes and metadata are all potential attack surfaces - every extra feature that makes data easy to use also creates a new way to misuse it.

Why Database Security Matters

Databases hold the organisation's most sensitive and mission-critical information - a breach rarely stays contained.

Financial loss

Fraud, theft, ransom payments

Reputational damage

Loss of customer & partner trust

Legal consequences

Regulatory fines (e.g. POPIA, GDPR)

The CIA Triad

Confidentiality

Only authorised access to data

Integrity

Data remains accurate and unaltered

Availability

Data & systems accessible when needed

In the news: South Africa recorded 2,374 formally reported breaches in the 2024/25 financial year alone - roughly one every 3 hours - according to the Information Regulator and industry reporting (ITWeb, 2026).

Integrity of the Database



Physical Integrity

Protects data from hardware failure, disaster or physical tampering.

e.g. RAID storage, redundant power supplies



Logical Integrity

Ensures stored data stays correct and valid as a whole.

e.g. blocking a transaction that creates a negative bank balance



Element Integrity

Ensures accuracy of each individual data value.

e.g. validation rules, ranges, primary/foreign key constraints



Element integrity protects against two things: accidental errors (typos, bad formats) and malicious alterations (tampering with records). Constraints like primary-key uniqueness and foreign-key relationships are the DBMS's first line of defence.

Auditability & Access Control



Auditability: logs of who did what and when - supports accountability, regulatory compliance, and detection of suspicious activity.

Access Control Models

DAC

Discretionary Access Control

The data owner decides who gets access - flexible, but relies on good judgement.

MAC

Mandatory Access Control

Access is fixed by classification level (e.g. Confidential, Secret) - common in government/military systems.

RBAC

Role-Based Access Control

Permissions follow job role (e.g. 'Nurse', 'Billing Clerk') - the standard in most modern enterprise systems.

Authentication & Availability



Authentication

Verifies a user's identity before granting database access.

- Passwords
- Biometrics (fingerprint, facial recognition)
- Multi-factor authentication (MFA)



Availability

Ensures database services remain accessible when needed.

- Replication & failover systems
- Regular backups for recovery
- Load balancing to prevent overload & downtime

Availability under attack: DDoS and ransomware both target this pillar directly - encrypting or flooding a database until it is unusable is now a routine extortion tactic.

Reliability & OS Protection Features

Security doesn't stop at the DBMS - the operating system underneath is just as important.



OS-Level Protections

Prevent unauthorised access to raw database files on disk.



Separation of Duties

Different system processes for different roles, reducing insider risk.



Secure File Permissions

Restrict read / write / execute rights to authorised accounts only.

Benefit: this defence-in-depth protects the integrity and confidentiality of database files even if the DBMS itself is bypassed.

The Two-Phase Update

How databases guarantee atomicity: either every change in a transaction happens, or none do.

PHASE 1 - PREPARE

- Lock affected data to prevent conflicts
- Write a commit flag in the transaction log indicating pending changes



PHASE 2 - COMMIT

- Apply all intended changes to the database
- Remove the commit flag from the log

Why it works: ensures atomicity, prevents partial/corrupted updates after a mid-process failure, and keeps the database consistent - the same principle behind ACID transactions in modern databases.

Redundancy, Recovery & Concurrency

Redundancy

- RAID storage tolerates disk failure
- Database replication keeps copies in sync

Recovery

- Transaction logs replay or roll back operations
- Checkpoints create stable save points
- Rollbacks undo incomplete/erroneous transactions

Concurrency Control

- Locks manage simultaneous access
- Timestamps order transactions
- Optimistic control detects conflicts without constant locking

What Makes Data 'Sensitive'?

Sensitivity isn't binary - it can arise in several different ways.



Inherently sensitive

Always confidential by nature - e.g. ID numbers, banking PINs, passwords



Sensitive source

Drawn from confidential systems - e.g. intelligence reports, patient medical records



Sensitive in context

Harmless alone, revealing when combined - e.g. birth date + postal code can uniquely identify someone



Temporal sensitivity

Harmless now, sensitive at a point in time - e.g. unreleased financial results, product launch dates

The Inference Problem

A user deduces sensitive information from data that isn't itself classified as sensitive - undermining security even when direct access is blocked.

1

Direct inference

Retrieving sensitive info outright via poor access control

2

Aggregation

Combining many small, non-sensitive facts into a sensitive whole

3

Negative result

Inferring meaning from the absence of expected data

4

Existence testing

Determining whether a record exists at all (e.g. 'does X have a criminal record?')

5

Probabilistic inference

Statistical analysis produces a highly accurate guess

Real example: researchers have repeatedly re-identified individuals in 'anonymised' datasets (health records, mobility data, location trails) by cross-referencing just a few quasi-identifiers - proving aggregation attacks are not theoretical.

Solutions for the Inference Problem



Data Suppression

Remove rare or identifying query results so individuals can't be pinpointed.



Data Modification

Add controlled statistical noise or swap values between records - preserves trends, hides identities.



Query Restrictions

Limit the number, type or complexity of queries a user can run.



View-Based Access Control

Give users restricted 'views' showing only aggregated, generalised or masked data.

Security vs. Precision

Database security often trades off protecting sensitive information against providing accurate, detailed data.



Stronger Security

= less precision. E.g. census data is rounded or small categories are suppressed so exact household counts can't reveal identities.



Higher Precision

= more research/business value, but greater privacy risk if the data can be linked back to individuals.

The DBA's challenge: find the balance that meets both security requirements and legitimate user needs - there is rarely a single 'correct' answer.

Data Mining

Analysing large datasets with statistics & machine learning to uncover hidden patterns, correlations, and trends.



Fraud Detection

Spotting unusual transactions signalling identity theft or card fraud



Customer Segmentation

Grouping customers by behaviour to tailor marketing



Recommendation Engines

Netflix / Amazon suggesting content based on past choices

Security & privacy implications

Positive

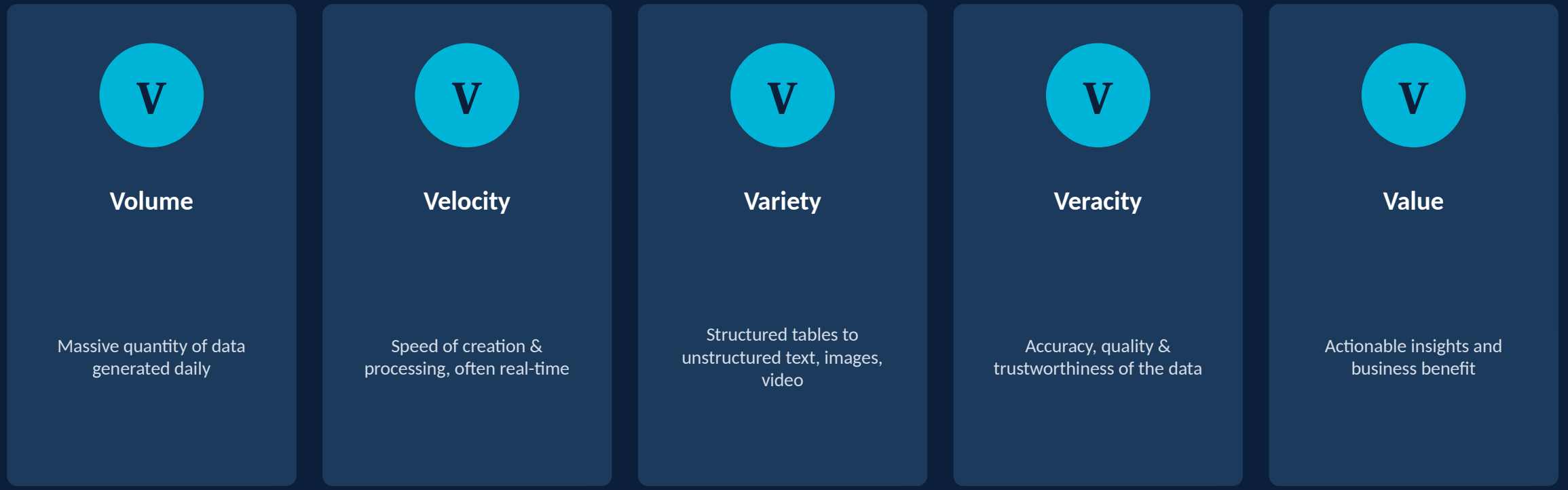
- Intrusion detection - spotting anomalies in network activity
- Fraud detection - flagging fraudulent transactions before damage occurs

Risks

- Privacy breaches - re-identifying people from 'anonymised' data
- Insider misuse - authorised staff mining data beyond their role

Big Data: The 5 V's

Datasets so large, fast and complex that traditional processing tools can't handle them effectively.



Security Challenges in Big Data

Access Control in Distributed Clusters

Ensuring only authorised users reach data spread across many servers

Encryption in Transit & at Rest

Protecting sensitive information from interception or theft

Privacy-Preserving Analytics

Useful analysis without exposing raw sensitive data (e.g. differential privacy)

Real-Time Security Monitoring

Detecting & responding to threats in high-speed, high-volume streams

In the News: South Africa

Database security is not an abstract exercise - these incidents happened in the last 18 months.



Standard Bank (2026)

Hackers exfiltrated roughly 1.2 TB of data, including client names, ID numbers, phone numbers and bank account details, then made some of it public - a stark illustration of confidentiality failure at Africa's largest bank.



Stats SA (Mar 2025)

The ransomware group 'XP95' breached an HR database of job applicants, compromising 400,000+ files and demanding a ~R1.7m ransom - a direct hit on a government database's availability & confidentiality.

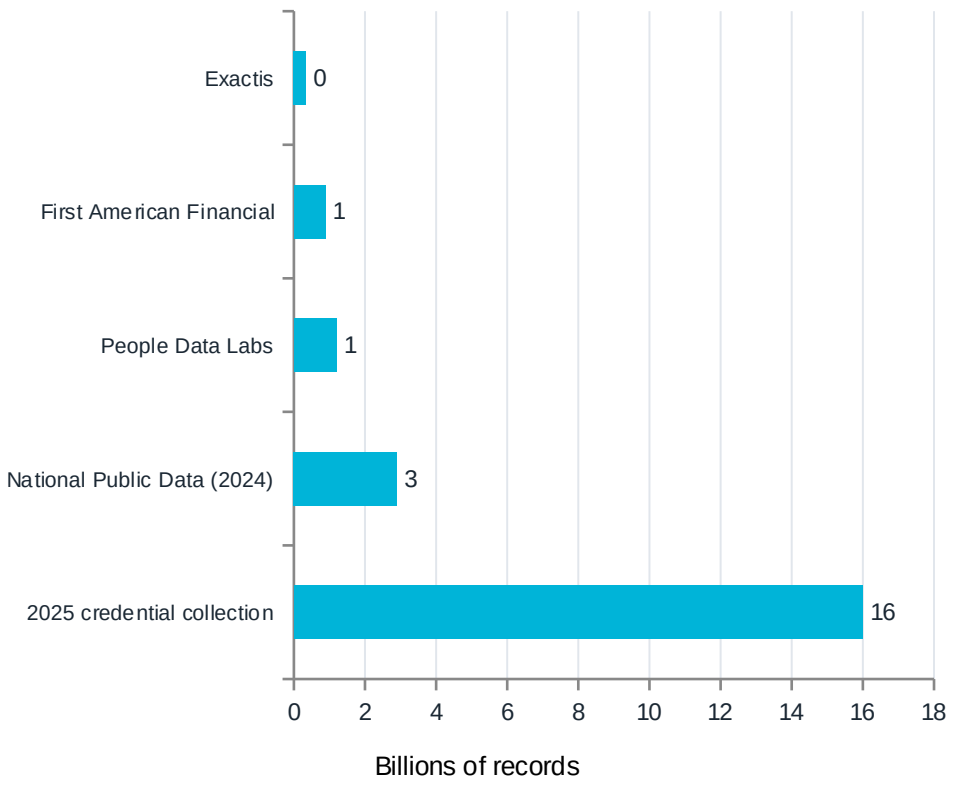


Pam Golding Properties (2025)

Unauthorised access to a high-value client CRM database exposed contact details, personal identifiers and transaction histories - showing even niche industries hold data worth stealing.

Sources: ITWeb (2026); Pinsent Masons / out-law.com (2025); teiss.co.uk (2026); Information Regulator SA reporting

In the News: Global Threats



2025 Credential Crisis (Jun 2025)

~16 billion login credentials found compiled online, mostly harvested by infostealer malware from personal and workplace devices - the largest credential exposure ever recorded (NordVPN, StationX).

Qantas / Vendor Supply Chain (2025)

Attackers compromised a third-party customer service platform to reach 5.7m Qantas customer records - highlighting how vendor databases have become the weak link ('island-hopping').

Sources: NordVPN (2026); StationX (2026); ProvenData (2025)

Connecting the Headlines Back to Theory

Almost every major breach traces back to one of the concepts covered in this unit.



Missing / weak access control

No DAC, MAC or RBAC enforced -> anyone who finds the database can read it (open databases behind most mega-breaches)



Weak authentication

Stolen or reused credentials remain the #1 breach vector (Verizon DBIR 2025)



Poor auditability

SA organisations take an average of 241 days to detect a breach - no monitoring layer on the database itself



Third-party / vendor risk

Supply-chain compromises (e.g. Qantas) show why every connected database is part of your attack surface



Knowledge Check

5 quick questions - play live as a Kahoot!-style quiz, or work through them as a class discussion.

Facilitator tip: recreate these 5 questions at kahoot.com (free account) for a live, gamified round with a leaderboard.

Q1 / 5

Which part of the CIA triad is directly attacked when a ransomware group encrypts a hospital's patient database?

A Confidentiality

B Integrity

C Availability ✓

D Auditability

Correct answer highlighted for facilitator view - hide before presenting live.

Q2 / 5

A user can't query salaries directly, but repeatedly combines job title, department and bonus data to work out a colleague's exact salary. This is an example of:

A. Direct inference

B. Aggregation ✓

C. Existence testing

D. Data suppression

Correct answer highlighted for facilitator view - hide before presenting live.

Q3 / 5

Which access control model assigns permissions based on a person's job function (e.g. 'Billing Clerk')?

A DAC

B MAC

C RBAC ✓

D ACID

Correct answer highlighted for facilitator view - hide before presenting live.

Q4 / 5

In the Two-Phase Update, what happens if a system fails during Phase 1 (Prepare)?

A. Changes are already permanent

B. The transaction is rolled back - nothing is applied ✓

C. Only half the data updates

D. The commit flag is ignored

Correct answer highlighted for facilitator view - hide before presenting live.

Q5 / 5

Which of the 5 V's of Big Data refers to the trustworthiness and accuracy of the data itself?

A Volume

B Velocity

C Veracity ✓

D Value

Correct answer highlighted for facilitator view - hide before presenting live.

Key Takeaways



The CIA triad (confidentiality, integrity, availability) frames every database security decision.



Access control (DAC/MAC/RBAC) + authentication + auditability form the practical defence layer.



Reliability mechanisms (two-phase update, redundancy, recovery, concurrency) keep data trustworthy under failure.



The inference problem shows that hiding a field isn't enough - aggregation and context can still leak secrets.



Data mining and Big Data (the 5 V's) multiply both the value and the risk of the data we hold.



These aren't textbook abstractions - Standard Bank, Stats SA and a 16-billion-credential leak happened in the last 18 months.



Thank You!

Any Questions?

References: Pfleeger & Pfleeger, Security in Computing (5th Ed.), Ch. 7 | ITWeb, Pinsent Masons, teiss.co.uk, NordVPN, StationX, ProvenData (2025-2026)